МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РФ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ БЮДЖЕТНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)
Факультет информационных технологий и компьютерной безопасности
Кафедра систем информационной безопасности

ОТЧЁТ
по научно-исследовательской работе студента

Тема: «Разработка интеллектуальной системы оценки киберрисков серверной инфраструктуры Linux в условиях эксплуатации ошибок конфигурирования сервисов»

Разработал студент
гр. ИБ-211 «_____» Н.П. Перушкин
Подпись, дата Инициалы, фамилия

Руководитель: «_____»
Подпись, дата, должность, инициалы, фамилия

Защищен _____ Оценка _____
дата

Воронеж 2026

СОДЕРЖАНИЕ

ВВЕДЕНИЕ 3
1 Модель угроз серверной инфраструктуры Linux на основе базы конфигурационных недостатков сервисов 10
1.1 Серверная инфраструктура Linux как объект защиты: сервисы, активы, модель эксплуатации 10
1.2 Ошибки конфигурирования сервисов как источник риска и их отличие от уязвимостей программного кода 13
1.3 Нормативно-правовое обеспечение защиты серверной инфраструктуры и требования к конфигурированию сервисов 16
1.4 Информационные источники сведений об ошибках конфигурирования и их сопоставление с техниками MITRE ATT&CK 18
1.5 Формирование базы соответствий «конфигурационный недостаток — эксплуатирующая техника — наступающий ущерб» 21
1.6 Классификация ошибок конфигурирования и построение дерева угроз и индуцированных ими рисков 23
1.7 Выводы по первой главе 28
СПИСОК ЛИТЕРАТУРЫ 29

ВВЕДЕНИЕ

Операционные системы семейства Linux занимают доминирующее положение в серверном сегменте. По данным веб-технологического обзора W3Techs, на сентябрь 2026 года среди веб-серверов, для которых удаётся определить операционную систему, доля Unix-подобных систем составляет 92,1 %, а собственно Linux — 62,5 % [1]. В российских условиях значимость этих систем усиливается курсом на импортозамещение: государственные информационные системы и значимые объекты критической информационной инфраструктуры переводятся на отечественные платформы, построенные на ядре Linux, что закреплено Указом Президента Российской Федерации от 30.03.2022 № 166 [2]. Наиболее распространённой из отечественных операционных систем этого класса называют Astra Linux [3]. Таким образом, защищённость всё большего числа информационных систем определяется тем, насколько корректно настроены системные и прикладные сервисы Linux.

Одновременно растёт число нацеленных на серверную инфраструктуру атак. Positive Technologies отмечает, что число атак в четвёртом квартале 2024 года выросло на 13 % по сравнению с аналогичным периодом предыдущего года [4]. При этом характер атак меняется: всё чаще нарушитель проникает в инфраструктуру не через сложный эксплойт, а через слабости периметра и учётных записей. По данным того же источника, в 44 % инцидентов точкой входа становились уязвимые веб-приложения на сетевом периметре, а доля атак через доверенные отношения с подрядчиками выросла до 15 % [5]. Масштаб ущерба тоже показателен: по оценке Экспертно-аналитического центра InfoWatch, за 2023–2025 годы в России утекло свыше 4,5 млрд записей персональных данных [6].

Существенную часть причин успешных атак составляют не дефекты программного кода, а ошибки конфигурирования сервисов. Показательны результаты мониторинга, проведённого компанией BI.ZONE: около 90 % организаций, использующих Linux, нарушают хотя бы одно требование методического документа ФСТЭК России по безопасной настройке, причём 48 % не соблюдают четыре и более требований, и лишь 8 % выполняют их полностью [7]. Автор исследования пря-

мо отмечает, что ошибки в настройках бывают столь же критичны, как и уязвимости в программном обеспечении, поскольку создают для нарушителя прямую точку входа [7]. Практические работы подтверждают этот тезис на конкретных примерах: в исследовании эксплуатации уязвимости BDU:2022-00488 (CVE-2021-4034) показано, как непривилегированный пользователь получает права суперпользователя на рабочей станции под управлением Debian и Astra Linux, после чего компрометирует ssh-ключи и закрепляется на удалённом сервере [3].

Ключевая особенность ошибки конфигурирования как источника риска в том, что она не является дефектом кода. Программа работает штатно, ровно так, как задано её параметрами, а опасное состояние возникает из-за значения, которое разработчик считает допустимым, но которое недопустимо в конкретных условиях эксплуатации. Из-за этого конфигурационный недостаток не получает идентификатора в справочниках уязвимостей: перечень CVE [8], национальная база NVD [9] и банк данных угроз ФСТЭК России [10] ориентированы прежде всего на уязвимости кода, привязанные к версии продукта. Как следствие, такой недостаток не принимается на вход и средствами количественной оценки — вектор CVSS [11, 12] рассчитывается для описанной в справочнике уязвимости, а прогноз вероятности эксплуатации EPSS [13] строится на статистике, накапливаемой по CVE-идентификатору, которого у ошибки конфигурирования попросту нет.

Существующие средства анализа защищённости выявляют конфигурационные недостатки, но не оценивают риск. Инструменты проверки соответствия профилю — OpenSCAP [14], Lynis [15], CIS-CAT [16], отечественный ScanOVAL [17], платформа Wazuh [18] — сравнивают фактические значения параметров с эталонными из руководств по безопасной настройке [19] и выдают результат в виде двоичного вердикта «соответствует / не соответствует» по каждому параметру. Такой результат не содержит меры риска, не позволяет сопоставить недостатки по величине возможного ущерба и не учитывает, что несколько безобидных по отдельности отклонений вместе образуют завершённую цепочку захвата узла. Кроме того, он отражает состояние системы лишь на момент проверки и устаревает при первом же изменении конфигурации.

Анализ публикаций показывает, что смежные с темой направления развиваются порознь. Риск-аналитический аппарат, развитый применительно к атакуемым сетям, эпидемическим процессам в них, картографии защищаемого киберпространства и организационно-правовой защите сетей [20–27], оперирует уязвимостями, у которых есть справочное описание и оценка критичности; работы по конфигурационным ошибкам заняты их обнаружением и классификацией, но не доводят результат до меры риска; средства анализа защищённости выполняют проверку соответствия, а не риск-анализ. В итоге конфигурационный недостаток — массовый и практически значимый источник ущерба — остаётся вне количественного риск-анализа серверной инфраструктуры. Этим определяется актуальность работы.

Актуальность темы обусловлена рядом противоречий:

– между объективной потребностью учёта ошибок конфигурирования сервисов при оценке киберрисков серверной инфраструктуры и ориентированностью действующих баз данных уязвимостей CVE, NVD и БДУ ФСТЭК России преимущественно на уязвимости программного кода, вследствие чего конфигурационный недостаток не получает идентификатора и выпадает из риск-анализа;

– между потребностью в количественной оценке критичности ошибок конфигурирования и возможностями существующих риск-калькуляторов CVSS 3.1, CVSS 4.0 и EPSS, рассчитанных на уязвимости, обладающие CVE-идентификатором и накопленной статистикой эксплуатации, которая для конфигурационных недостатков отсутствует;

– между необходимостью учёта взаимного влияния конфигурационных недостатков, образующих цепочки повышения привилегий и перемещения внутри периметра, и единичным, пообъектным характером проверок существующих средств анализа защищённости OpenSCAP, Lynis, CIS-CAT, ScanOVAL и Wazuh;

– между потребностью в непрерывной переоценке риск-ландшафта при изменении конфигурации защищаемой инфраструктуры и статичностью действующих методик, предполагающих разовое обследование серверов по фиксированному профилю соответствия с последующим устареванием результатов;

– между сложившейся практикой регламентации мер защиты в отношении отдельного сервера или сервиса и объективной необходимостью регулирования рисков серверной инфраструктуры как связной системы при множественной эксплуатации конфигурационных недостатков.

Объект исследования — серверная инфраструктура на базе операционных систем семейства Linux, включая системные и прикладные сервисы, их конфигурации и обрабатываемые ими информационные активы.

Предмет исследования — модели, методики и алгоритмы оценки киберрисков, позволяющие количественно описывать вероятность и ущерб от эксплуатации ошибок конфигурирования сервисов и регулировать риск-ландшафт серверной инфраструктуры.

Цель работы — повышение защищённости серверной инфраструктуры Linux от угроз, реализуемых через эксплуатацию ошибок конфигурирования сервисов, за счёт разработки интеллектуальной системы количественной оценки соответствующих киберрисков.

Для достижения цели решаются следующие задачи:

– организовать сбор и систематизацию сведений об ошибках конфигурирования сервисов Linux из открытых источников — CIS Benchmarks, DISA STIG, SCAP-контента, CWE и БДУ ФСТЭК России — с формированием структурированной базы троек «конфигурационный недостаток — эксплуатирующая техника — наступающий ущерб» и построить на её основе дерево угроз и индуцированных ими рисков серверной инфраструктуры;

– разработать методику количественной оценки критичности ошибок конфигурирования, не имеющих CVE-идентификатора, на основе адаптации базовых и контекстных метрик CVSS 4.0 и построить модель машинного обучения, обучаемую на размеченных записях банка данных угроз и NVD и переносящую полученную оценку критичности на конфигурационные недостатки;

– сформировать сценарии эксплуатации конфигурационных недостатков в виде последовательностей техник MITRE ATT&CK на основе построенного дерева угроз с расчётом риска успешности каждого сценария на графе атак;

– разработать алгоритмическое и программное обеспечение интеллектуальной системы, выполняющей построение риск-ландшафта серверной инфраструктуры и его пересчёт при смене снимка конфигурации;

– сформировать комплекс мер риск-регулирования, классифицированных по масштабности и профильности, и частные регламенты реагирования и ликвидации последствий эксплуатации ошибок конфигурирования сервисов.

Методы исследования. В работе применяются методы системного анализа и декомпозиции сложных систем, аппарат теории рисков, методы теории вероятностей и математической статистики, теория графов при построении дерева угроз и графа достижимости активов, методы машинного обучения с учителем при восстановлении оценок критичности и методы поиска аномалий при анализе конфигураций, а также методы объектно-ориентированного программирования при разработке программного обеспечения.

Результаты, выносимые на защиту, обладают следующей новизной:

– база знаний соответствий конфигурационных недостатков и техник их эксплуатации, охватывающая удалённый доступ, аутентификацию, файловую систему и права, сетевые сервисы, механизмы изоляции, планировщики заданий, журналирование и управление пакетами, и построенное на её основе дерево угроз и индуцированных рисков серверной инфраструктуры Linux; известные средства привязывают анализ к перечню установленного программного обеспечения, здесь же ошибки конфигурирования сведены с техниками их эксплуатации в единое признаковое пространство, привязанное к активам, а дерево угроз построено по конфигурационным недостаткам сервисов, а не по уязвимостям программного кода;

– методическое и алгоритмическое обеспечение расчёта меры риска эксплуатации конфигурационного недостатка как произведения ущерба на вероятность его наступления и обученная модель, проставляющая оценку критичности недостаткам, не имеющим справочного описания; существующие калькуляторы вообще не принимают конфигурационный недостаток на вход из-за отсутствия у него CVE-идентификатора, тогда как предложенный подход даёт для него количественную

оценку критичности, а недостающие значения восстанавливает модель, обученная на записях с уже известными оценками;

– множество сценариев эксплуатации конфигурационных недостатков, построенных на основе дерева угроз, с рассчитанной мерой риска успешности каждого сценария; если аналоги ограничиваются дискретной проверкой соответствия по каждому параметру в отдельности, то предложенный подход определяет риск связностью конфигурационных недостатков, образующих сценарий достижения защищаемого актива;

– риск-ландшафт серверной инфраструктуры в измерениях «актив — техника — мера риска» и программное обеспечение интеллектуальной системы, поддерживающее его в актуальном состоянии; в отличие от действующих методик, дающих разовый снимок соответствия, риск-ландшафт перестраивается при каждом изменении конфигурации с отображением её вклада в изменение меры риска и потому всегда отвечает текущему состоянию инфраструктуры;

– комплекс мер, политик и частных регламентов противодействия эксплуатации ошибок конфигурирования и количественная оценка снижения риск-ландшафта серверной инфраструктуры после их внедрения; вместо привычной оценки мер по достигнутому проценту соответствия профилю предложенные меры соотнесены с конкретными узлами дерева угроз и оцениваются величиной снижения меры риска.

Практическая ценность результатов состоит в следующем: база знаний и дерево угроз представляют собой готовый перечень проверяемых параметров конфигурации с указанием эксплуатирующей техники и ожидаемого ущерба, а также наглядную структуру угроз, пригодные при проектировании защиты серверной инфраструктуры; методика оценки критичности позволяет оперативно вычислять параметры риска отдельного конфигурационного недостатка и ранжировать серверы и сервисы по критичности; множество сценариев эксплуатации помогает увидеть, какие сочетания конфигурационных недостатков приводят нарушителя к привилегиям суперпользователя, и устранять недостатки в порядке их вклада в сценарий; программное обеспечение интеллектуальной системы избавляет от повторного ручного аудита при каждом изменении конфигурации и позволяет наблюдать динамику за-

щищённости инфраструктуры во времени; комплекс мер риск-регулирования служит обоснованием выбора мер защиты по критерию предотвращаемого ущерба и основой для частных инструкций системным администраторам.

Теоретическая значимость состоит в том, что база соответствий создаёт основу для распространения полученного соответствия и дерева угроз на иные операционные системы и сетевое оборудование; методика оценки критичности намечает путь к применению машинного восстановления оценок для других классов недостатков без справочного описания, включая организационные и процедурные; подход к формированию сценариев эксплуатации позволяет адаптировать набор сценариев под конкретную инфраструктуру, сокращая его до актуального или, наоборот, распространяя на разнородные серверные среды; модель риск-ландшафта даёт теоретическую базу для оптимизации риск-ландшафта серверных инфраструктур различного назначения; комплекс мер риск-регулирования ведёт к формированию типовых политик противодействия для серверных инфраструктур различного назначения.

1 Модель угроз серверной инфраструктуры Linux на основе базы конфигурационных недостатков сервисов

1.1 Серверная инфраструктура Linux как объект защиты: сервисы, активы, модель эксплуатации

Под серверной инфраструктурой здесь понимается совокупность вычислительных узлов под управлением операционных систем семейства Linux, установленных на них системных и прикладных сервисов и средств их взаимодействия, обеспечивающих обработку информации в интересах организации. Узел может быть физическим сервером, виртуальной машиной или экземпляром контейнерной среды; для риск-анализа важно не физическое воплощение узла, а набор его сервисов и состояние их настроек.

Выбор Linux в качестве объекта исследования объясняется его преобладанием в серверном сегменте [1], открытостью кода и конфигурационных механизмов, которая допускает формализованный анализ настроек, и единообразием этих механизмов между дистрибутивами; отдельного внимания заслуживают отечественные дистрибутивы, применяемые в рамках импортозамещения [3]. Несмотря на различия в системах управления пакетами и наборах служб по умолчанию, подсистемы разграничения доступа, управления службами, регистрации событий и мандатного контроля [28] в современных дистрибутивах устроены на общих принципах [29]. Это позволяет строить модель объекта защиты, не привязанную к конкретному дистрибутиву.

Главная особенность такой инфраструктуры как объекта защиты в том, что её защищённость определяется не только применяемыми средствами защиты информации, но и состоянием настроек штатных механизмов ОС и сервисов. Один и тот же продукт одной и той же версии, свободный от известных уязвимостей кода, в зависимости от значений параметров может быть либо недоступен нарушителю, либо открывать ему прямой путь к данным. Именно поэтому конфигурация становится самостоятельным предметом риск-анализа [30].

В составе инфраструктуры выделим восемь групп сервисов и механизмов, различающихся назначением и характером присущих им конфигурационных недостатков. Эта группировка положена в основу дальнейшей классификации и приведена в таблице 1.

Таблица 1 – Группы сервисов и механизмов серверной инфраструктуры Linux

Обозначение	**Группа**	**Состав и назначение**	**Контролируемые параметры**
G1	Сервисы удалённого доступа	Службы интерактивного управления узлом, прежде всего сервер защищённой оболочки [31]	Разрешение входа суперпользователя, способы аутентификации, криптоалгоритмы, ограничение попыток, перечень допущенных пользователей
G2	Идентификация и аутентификация	Подсистема подключаемых модулей [32], база учётных записей, политики паролей	Стойкость и срок действия пароля, блокировка после неудач, учётные записи с пустым паролем, многофакторное подтверждение
G3	Файловая система и права	Права на файлы и каталоги, специальные биты, повышение полномочий [33]	Права на файлы конфигурации, файлы с битом смены владельца, параметры монтирования, правила sudo
G4	Сетевые сервисы	Веб-серверы, СУБД, службы хранения, файловые службы	Интерфейсы прослушивания, обязательность аутентификации, шифрование канала, допущенные сети, анонимный доступ
G5	Механизмы изоляции	Мандатное разграничение [28], среды контейнеризации [34]	Режим мандатного контроля, привилегированный контейнер, монтирование каталогов узла, доступ к управляющему сокету
G6	Планировщики заданий	Служба периодических заданий, таймеры	Учётная запись выполнения задания, права на каталоги заданий, перечень допущенных пользователей
G7	Журналирование	Служба регистрации событий, системный журнал	Состав регистрируемых событий, централизованная передача, права на журналы, глубина хранения
G8	Управление пакетами	Подсистема установки и обновления ПО	Источники пакетов, проверка подписи, периодичность установки обновлений безопасности

Все перечисленные механизмы наблюдаемы непосредственно в самой операционной системе и не требуют внешних источников данных. Это важно для автоматизации: снимок конфигурации узла снимается штатными средствами, без установки дополнительного ПО на защищаемый узел.

Введём обозначения для последующей формализации. Пусть N — множество узлов инфраструктуры, S — множество развёрнутых на них сервисов, причём каждому узлу n сопоставлено подмножество сервисов S(n). Каждый сервис s описывается набором конфигурационных параметров, значения которых в момент времени t образуют вектор конфигурации c(s, t). Совокупность таких векторов по всем сервисам даёт снимок конфигурации C(t). Через A обозначим множество защищаемых активов, через R(n, a) — отношение достижимости актива a с узла n. Мера риска инфраструктуры вычисляется на основе снимка C(t), множества активов A и отношения достижимости.

Связь субъектов доступа, сервисов и защищаемых активов образует модель объекта защиты, представлена рисунке 1.

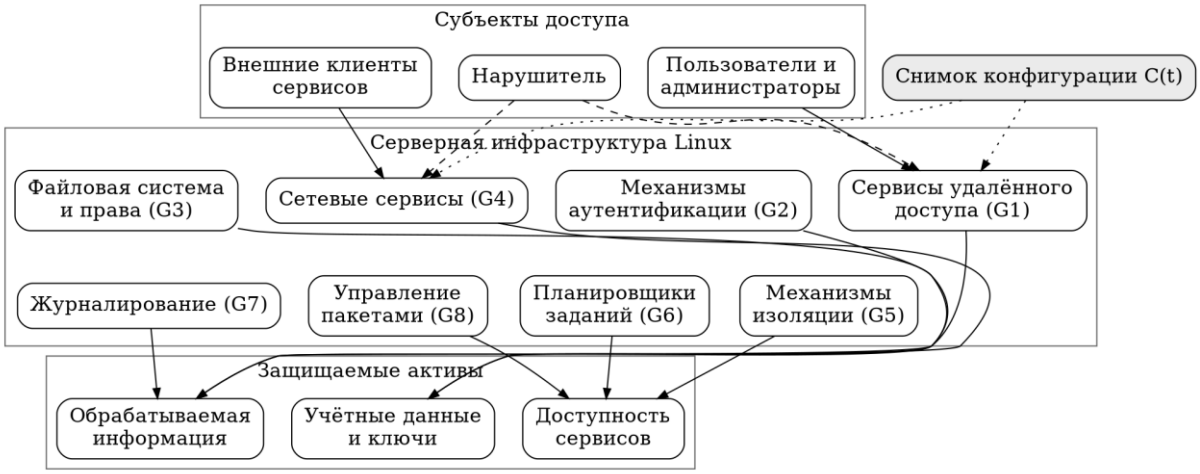


Рисунок 1 – Модель серверной инфраструктуры Linux как объекта защиты

Модель показывает, что сервисы стоят между субъектами доступа и активами, а конфигурация задаёт условия, при которых доступ разрешается или блокируется. Нарушитель, не располагающий дефектом кода, работает с инфраструктурой через те же штатные механизмы, что и легитимный пользователь, и успех его действий целиком определяется значениями параметров [3].

Защищаемые активы неоднородны по последствиям нарушения их безопасности. Первая категория — обрабатываемая информация: персональные данные, коммерческая тайна, технологические сведения; нарушение их конфиденциальности или целостности даёт прямой и правовой ущерб. Вторая — учётные данные и крип-

тографические ключи на узлах; их компрометация не наносит ущерба сама по себе, но открывает путь к остальным активам и обеспечивает перемещение внутри периметра [3]. Третья — доступность сервисов, нарушение которой ведёт к простою системы и связанным с ним потерям.

Обстоятельства, определяющие риск эксплуатации ошибки конфигурирования, наблюдаемы и измеримы. К ним относятся:

– атрибуты доступности — интерфейсы прослушивания, наличие сетевой фильтрации, достижимость сервиса извне;

– атрибуты аутентификации — обязательность подтверждения личности, применяемый способ, стойкость допускаемых паролей;

– атрибуты полномочий — учётная запись, от имени которой работает сервис, объём её прав, наличие правил безусловного повышения полномочий;

– атрибуты изоляции — режим мандатного контроля, параметры запуска контейнеров, ограничения на системные вызовы;

– атрибуты наблюдаемости — состав регистрируемых событий, централизованное хранение журналов, возможность восстановить ход инцидента;

– атрибуты значимости — категории достижимых с узла активов, участие узла в обработке персональных данных или в составе значимого объекта КИИ.

Эти свойства образуют признаковое пространство узла и сервиса, в котором во втором разделе решаются задачи количественной оценки критичности и поиска аномальных настроек.

1.2 Ошибки конфигурирования сервисов как источник риска и их отличие от уязвимостей программного кода

По ГОСТ Р 56546 уязвимость информационной системы определяется как её недостаток, использование которого нарушителем способно привести к реализации угрозы безопасности информации [35]. Приведённая в стандарте классификация выделяет уязвимости по области происхождения, и наряду с уязвимостями кода в самостоятельные классы отнесены уязвимости конфигурации, архитектуры и органи-

зационные. То есть отечественная нормативная база признаёт конфигурационный недостаток разновидностью уязвимости, но практика ведения справочников за этим признанием не поспевает.

В международной терминологии конфигурационные недостатки отражены перечнем типов слабостей CWE [36]: небезопасное значение по умолчанию, некорректное назначение прав, применение встроенных учётных данных и другие. Перечень описывает типы слабостей, а не конкретные экземпляры в конкретных системах, и не содержит количественных оценок.

Определим ошибку конфигурирования сервиса как значение конфигурационного параметра, допустимое с точки зрения разработчика и не являющееся дефектом кода, но в условиях эксплуатации порождающее состояние, использование которого нарушителем ведёт к реализации угрозы. Из этого определения вытекает ряд особенностей, важных для методики риск-анализа.

Во-первых, ошибка конфигурирования не привязана к версии продукта. Уязвимость кода существует в конкретных версиях и закрывается обновлением; конфигурационный недостаток воспроизводится в любой версии, потому что его причина — выбранное значение параметра, а не реализация. Отсюда и другой способ устранения: не обновление, а изменение параметра, что не несёт риска несовместимости, но требует понимания функциональных последствий [30].

Во-вторых, у такого недостатка нет идентификатора в справочниках. Присвоение CVE предполагает дефект в конкретном продукте конкретного производителя [8], а состояние, возникшее из-за выбора администратором допустимого значения, под это условие не подпадает. Поэтому недостаток отсутствует в NVD [9] и банке данных угроз ФСТЭК России [10] и не получает прогноза вероятности эксплуатации [13].

В-третьих, у ошибки конфигурирования иной жизненный цикл. Уязвимость кода появляется с выпуском версии и исчезает с установкой обновления, то есть является внешним для организации событием. Конфигурационный недостаток возникает при развёртывании или изменении настроек, то есть порождается действиями самой организации, и может вернуться после отката конфигурации, восстановления

из резервной копии или ручной правки. Постепенное расхождение фактической конфигурации с утверждённой — конфигурационный дрейф — исследовано в работах по эксплуатации программных систем [37, 38] и является одной из главных причин устаревания разового обследования.

В-четвёртых, ответственность за появление недостатка во многом лежит не на квалификации администратора, а на проектных решениях разработчика. Значительная доля ошибок вызвана небезопасными значениями по умолчанию и сложностью самих конфигурационных механизмов [37]. Для риск-регулирования это существенно: организационные меры, адресованные только администратору, без автоматизированного контроля настроек оказываются недостаточными [7].

Сопоставление уязвимости кода и ошибки конфигурирования по признакам, важным для риск-анализа, приведено в таблице 2.

Таблица 2 – Сопоставление уязвимости программного кода и ошибки конфигурирования

Признак	**Уязвимость программного кода**	**Ошибка конфигурирования**
Причина	Дефект реализации продукта	Значение параметра, выбранное при развёртывании или эксплуатации
Идентификатор	CVE, запись в NVD и банке данных угроз	Отсутствует, есть лишь ссылка на пункт руководства по настройке
Количественная оценка	Вектор CVSS, прогноз EPSS	Отсутствует, результат проверки двоичный
Зависимость от версии	Есть в конкретных версиях	Воспроизводится в любой версии
Способ устранения	Установка обновления	Изменение значения параметра
Способ обнаружения	Сверка версии с базой уязвимостей	Сверка значений параметров с эталонным профилем
Повторное появление	Исключено после обновления	Возможно из-за конфигурационного дрейфа
Источник сведений	CVE, NVD, банк данных угроз	CIS Benchmarks, DISA STIG, SCAP, CWE

Главный вывод подраздела: ошибка конфигурирования — полноценный источник риска, но её не берут в обработку инструменты, созданные для уязвимостей кода. Существующий аппарат использует идентификатор уязвимости как ключ, по которому доступны оценка критичности, статистика эксплуатации и сведения о

наличии средств эксплуатации; для конфигурационного недостатка этого ключа нет, поэтому он либо исключается из риск-анализа, либо учитывается двоичным признаком соответствия, несопоставимым с мерой риска.

Практическую значимость этого класса недостатков подтверждает статистика. Мониторинг BI.ZONE показал, что около 90 % организаций с Linux-инфраструктурой нарушают хотя бы одно требование методики ФСТЭК России, а почти половина — четыре и более [7]. Positive Technologies отмечает, что в 44 % инцидентов точкой входа служил уязвимый периметр [5], а исследование эксплуатации BDU:2022-00488 демонстрирует, как из конфигурационных предпосылок разворачивается полная цепочка компрометации узла [3]. Получается, что самый распространённый на практике класс недостатков хуже всего обеспечен аппаратом количественной оценки — это и есть содержание первого из выявленных противоречий.

1.3 Нормативно-правовое обеспечение защиты серверной инфраструктуры и требования к конфигурированию сервисов

Требования к защите информации в серверной инфраструктуре задаёт совокупность нормативных актов и методических документов. Основу отечественного регулирования образуют федеральные законы об информации [39], о персональных данных [40] и о безопасности критической информационной инфраструктуры [41]. Курс на переход КИИ и госсектора на отечественные решения закреплён Указом Президента [2]. Базовые термины определены ГОСТ Р 50922 [42].

Состав и содержание мер защиты установлены приказами ФСТЭК России — для государственных информационных систем [43], информационных систем персональных данных [44] и значимых объектов КИИ [45]. Порядок определения актуальных угроз, включая модель нарушителя и сценарии реализации угроз, задан методикой оценки угроз [46], а конкретные требования к настройке Linux — методическим документом ФСТЭК России по безопасной настройке [47]. Именно последний документ прямо связывает нормативные требования с конфигурационными параметрами и потому особенно важен для темы работы.

Меры, относящиеся к предмету исследования, сосредоточены в группах по идентификации и аутентификации, управлению доступом, ограничению программной среды, регистрации событий, обеспечению целостности и защите среды виртуализации. Их содержание и отражение в конфигурации сервисов Linux приведены в таблице 3 (обобщение по требованиям приказов ФСТЭК и рекомендациям по безопасной настройке [7, 43, 47]).

Таблица 3 – Меры защиты информации и их отражение в конфигурации сервисов Linux

Группа мер	**Содержание требования**	**Отражение в конфигурации**	**Группа сервисов**
Идентификация и аутентификация	Управление идентификаторами и средствами аутентификации, правила паролей	Стойкость и срок пароля, блокировка после неудач, запрет пустых паролей	G2
Управление доступом	Управление учётными записями, разграничение прав, ограничение попыток входа	Запрет входа суперпользователя, правила sudo, права на файлы, допущенные сети	G1, G3, G4
Ограничение программной среды	Управление запуском ПО, установка и обновление разрешённого ПО	Проверка подписи пакетов, доверенные источники, ограничение запуска исполняемых файлов	G8
Регистрация событий	Состав регистрируемых событий, сбор, хранение и защита журналов	Правила регистрации, централизованная передача, права на журналы, глубина хранения	G7
Обеспечение целостности	Контроль целостности ПО и информации	Контроль неизменности файлов конфигурации и исполняемых файлов	G3, G8
Защита среды виртуализации	Разграничение доступа к компонентам виртуальной инфраструктуры	Режим мандатного контроля, параметры запуска контейнеров, доступ к сокету	G5
Защита каналов	Защита каналов передачи и интерфейсов управления	Шифрование канала, ограничение интерфейсов прослушивания, криптоалгоритмы	G1, G4

Легко заметить, что требования формулируются в терминах наличия или отсутствия меры. Требование об управлении доступом предписывает разграничивать права, но не говорит, во сколько раз возрастает риск при правиле безусловного повышения полномочий для конкретной учётной записи и насколько этот риск отличается от риска доступной со всех интерфейсов службы хранения данных. Результат проверки — двоичный вердикт, а сопоставления узлов по величине риска норматив-

ные документы не предусматривают. При ограниченном ресурсе администратора это лишает обоснованного порядка устранения недостатков [7].

Требования к менеджменту риска вынесены в отдельную группу документов. Общие принципы заданы ГОСТ Р ИСО 31000 [48], применительно к ИБ — ГОСТ Р ИСО/МЭК 27005 [49]. Эти документы задают процессную рамку управления риском, но не дают методики вычисления меры риска для конкретного конфигурационного недостатка.

Зарубежная база устроена похоже. Руководство по общей безопасности серверов [50] содержит рекомендации по безопасной настройке, а методика оценки риска [51] задаёт общий порядок её проведения. Наиболее детальные требования к значениям параметров содержатся в руководствах по безопасной настройке [19, 52], которые рассматриваются в следующем подразделе.

Итог подраздела: нормативное обеспечение задаёт требуемый состав мер и требуемые значения отдельных параметров, но не даёт средств количественно сопоставить конфигурационные недостатки по величине индуцируемого риска. Это подтверждает второе противоречие и обосновывает разработку методики количественной оценки критичности во втором разделе.

1.4 Информационные источники сведений об ошибках конфигурирования и их сопоставление с техниками MITRE ATT&CK

Чтобы построить базу соответствий, сначала нужно определить, откуда брать сведения о конфигурационных недостатках и как связать их с действиями нарушителя. Информационные ресурсы, пригодные для этого, различаются предметом описания, и по отдельности ни один из них не даёт полной картины «недостаток — способ эксплуатации — последствие».

Перечень CVE [8] и построенная на нём база NVD [9] описывают уязвимости программного кода конкретных продуктов и, как показано выше, для конфигурационных недостатков напрямую неприменимы. Банк данных угроз ФСТЭК России [10] полезнее: помимо уязвимостей он содержит перечень угроз безопасности информа-

ции с указанием нарушаемых свойств и объектов воздействия, что позволяет привязать конфигурационный недостаток к угрозе. Перечень типов слабостей CWE [36] задаёт таксономию причин возникновения недостатков. Классификация шаблонов атак CAPEC [53] описывает обобщённые способы нападения, а матрица MITRE ATT&CK [54] — конкретные техники, наблюдаемые в реальных атаках, и именно она даёт связь между недостатком и действием, которым он эксплуатируется.

Эталонные значения параметров содержатся в руководствах по безопасной настройке. Наиболее полны руководства Центра интернет-безопасности CIS Benchmarks [19], выпускаемые отдельно под каждый дистрибутив [55], и руководства по технической реализации требований DISA STIG [52]. Машиночитаемое представление обеспечивает протокол автоматизации SCAP [56] с языком описания проверок OVAL. Эти ресурсы и есть основной источник перечня недостатков: каждый пункт руководства по настройке фактически описывает один потенциальный недостаток — проверяемый параметр, эталонное значение и обоснование. На то, что несоблюдение этих требований носит массовый характер, прямо указывают результаты мониторинга BI.ZONE [7].

Требования отечественного регулятора к безопасной настройке Linux собраны в методическом документе ФСТЭК России [47], а отдельные меры детализированы в практических руководствах [30]. Сопоставление рассмотренных ресурсов по применимости к задаче приведено в таблице 4.

Таблица 4 – Информационные ресурсы и их применимость к анализу ошибок конфигурирования

Ресурс	**Что описывает**	**Количественная оценка**	**Применимость к конфигурационным недостаткам**
CVE, NVD	Уязвимости кода	Вектор CVSS	Низкая: недостатки не регистрируются
БДУ ФСТЭК России	Уязвимости и угрозы	Уровень опасности угрозы	Средняя: годится для привязки к угрозам и как размеченная выборка
CWE	Типы слабостей	Нет	Высокая: таксономия причин возникновения
CAPEC	Шаблоны атак	Качественные оценки	Средняя: обобщённый уровень

Продолжение таблицы 4

Ресурс	Что описывает	Количественная оценка	Применимость к конфигурационным недостаткам
MITRE ATT&CK	Техники нарушителя	Нет	Высокая: связь недостатка с действием нарушителя
CIS Benchmarks	Эталонные значения параметров	Двоичный вердикт	Высокая: основной источник перечня недостатков
DISA STIG	Требования к настройке с градацией важности	Три категории важности	Высокая: качественная градация значимости
SCAP, OVAL	Машиночитаемые проверки	Нет	Высокая: автоматизация сбора данных

Выявлением конфигурационных недостатков занимается отдельный класс программных средств, и его обзор нужен, чтобы очертить границы существующих возможностей. Средства проверки соответствия профилю сверяют фактические значения параметров с эталонными: открытая реализация OpenSCAP [14], аудитор Lynis [15], инструмент CIS-CAT [16], отечественный ScanOVAL [17] и платформа мониторинга Wazuh [18]. Сетевые сканеры и системы управления уязвимостями — Nessus [57] и отечественный MaxPatrol VM [58] — выполняют инвентаризацию и поиск известных уязвимостей, включая ограниченный набор конфигурационных проверок. Отдельно стоят средства статического анализа описаний инфраструктуры как кода, контроля поведения во время исполнения и автоматизации конфигурирования, применяемые для приведения настроек к утверждённому состоянию. Общий недостаток перечисленных средств в том, что они решают задачу обнаружения, но не доводят результат до меры риска и проверяют параметры по отдельности, без учёта их связности.

Способ эксплуатации недостатка описывается через технику ATT&CK. Каждому недостатку ставится в соответствие одна или несколько техник по описанию техники, перечню условий её применения и приводимым примерам. Так, разрешённый вход суперпользователя по сети через сервер защищённой оболочки [31] эксплуатируется подбором учётных данных, а правило безусловного повышения полномочий [33] — злоупотреблением механизмом sudo, что в матрице соответствует технике повышения привилегий [54]. Практические работы подтверждают такие

связки на конкретных примерах: в исследовании эксплуатации уязвимости pkexec показано, как штатный механизм превращается в средство повышения привилегий [3].

Последствие эксплуатации выражается через нарушаемые свойства безопасности информации — конфиденциальность, целостность, доступность — и через категорию достигаемого результата: доступ к сервису, получение учётных данных, повышение полномочий, закрепление, перемещение внутри периметра, нарушение работоспособности, сокрытие следов. Классификация нарушаемых свойств опирается на ГОСТ Р 50922 [42] и методику оценки угроз [46].

1.5 Формирование базы соответствий «конфигурационный недостаток — эксплуатирующая техника — наступающий ущерб»

Решение первой задачи — свести разрозненные сведения в единую структуру, где каждый недостаток связан со способом эксплуатации и последствием. Необходимость такой базы в том, что единого справочника конфигурационных недостатков не существует: сведения рассеяны по руководствам CIS и DISA, машиночитаемому SCAP-контенту и перечню CWE, и ни один из этих источников не указывает одновременно и способ эксплуатации, и последствия [7].

База формируется в четыре шага. Сначала из руководств [55], требований DISA STIG [52] и SCAP-контента [56] извлекается перечень проверяемых параметров; каждый пункт превращается в запись с идентификатором, проверяемым параметром, эталонным значением и группой сервисов из таблицы 1. Затем записи сопоставляется тип слабости из CWE [36]. Дальше — техника или несколько техник ATT&CK [54], эксплуатирующих недостаток. Наконец, определяется наступающий ущерб — нарушаемые свойства и категория достигаемого результата.

Запись базы описывается кортежем: идентификатор недостатка, группа сервисов, контролируемый параметр, эталонное и опасное значения, тип слабости, эксплуатирующие техники, нарушаемые свойства, категория результата и предварительная качественная значимость (по степени важности требования в руководстве

по настройке). Такая структура задаёт единое признаковое пространство, в котором во второй главе выполняется количественная оценка критичности. Фрагмент базы приведён в таблице 5, полный перечень вынесен в приложение А.

Таблица 5 – Фрагмент базы соответствий конфигурационных недостатков и техник эксплуатации

Группа	**Конфигурационный недостаток**	**Тип слабости**	**Техника ATT&CK**	**Достигаемый результат**
G1	Разрешён вход суперпользователя по сети через сервер защищённой оболочки	CWE-1188	T1078.003; T1110	Доступ к узлу с правами суперпользователя
G1	Разрешена парольная аутентификация без ограничения попыток	CWE-307	T1110.001	Получение учётных данных
G2	Нет требований к стойкости и сроку действия пароля	CWE-521	T1110.002	Получение учётных данных
G2	Есть учётные записи с пустым паролем	CWE-258	T1078	Доступ к узлу
G3	Избыточные права на файлы конфигурации сервисов	CWE-732	T1222	Изменение конфигурации, закрепление
G3	Правило безусловного повышения полномочий без запроса пароля	CWE-250	T1548.003	Повышение полномочий до суперпользователя
G4	Служба хранения данных доступна со всех интерфейсов без аутентификации	CWE-306	T1190	Доступ к обрабатываемой информации
G4	Передача данных сервисом идёт без шифрования	CWE-319	T1040	Компрометация учётных данных
G5	Отключено мандатное разграничение доступа	CWE-693	T1562.001	Снятие ограничений на действия нарушителя
G5	Контейнер запущен в привилегированном режиме	CWE-250	T1611	Получение полномочий на узле
G6	Задание планировщика выполняется от суперпользователя	CWE-250	T1053.003	Закрепление, повышение полномочий
G7	Регистрация событий безопасности отключена	CWE-778	T1562.008	Сокрытие следов
G8	Отключена проверка подписи пакетов	CWE-347	T1195.002	Выполнение недоверенного кода

Фрагмент показывает главное свойство базы: недостатки, у которых нет идентификаторов в справочниках уязвимостей, получают описание в тех же терминах, что и действия нарушителя, и становятся сопоставимыми с уязвимостями кода на уровне достигаемого результата. Тем самым устраняется разрыв между перечнем

проверяемых параметров, который дают средства аудита, и моделью угроз, которую требует методика оценки угроз [46].

Важно, что одному недостатку обычно соответствует несколько техник, а одна техника достижима через разные недостатки. Полученное отношение — «многие ко многим»; оно образует двудольный граф, где одна доля вершин это недостатки, другая — техники. Это представление используется в третьей главе при построении сценариев: сценарий определяется как путь в графе, связывающий исходное положение нарушителя с достижением защищаемого актива [59].

1.6 Классификация ошибок конфигурирования и построение дерева угроз и индуцированных ими рисков

База соответствий позволяет перейти к классификации недостатков и построению дерева угроз. Методические рекомендации предписывают строить такое дерево в первой главе и делать его основой всего дальнейшего исследования, обеспечивая полноту охвата угроз; фрагментарный анализ методика прямо запрещает [60].

Недостатки классифицируются по двум независимым основаниям. Первое — группа сервисов (таблица 1), оно отражает структуру объекта защиты. Второе — механизм возникновения опасного состояния, оно определяет характер риска и способ устранения. По второму основанию выделяются:

– недостатки доступности — служба открыта более широкому кругу, чем нужно (доступность со всех интерфейсов, отсутствие ограничения по сетям);

– недостатки аутентификации — подтверждение личности не требуется, идёт по пустым или предустановленным данным либо допускает неограниченный подбор;

– недостатки разграничения полномочий — субъекту или сервису дано больше прав, чем необходимо (работа от суперпользователя, безусловное повышение полномочий);

– недостатки изоляции — механизмы ограничения среды отключены или ослаблены (отключённый мандатный контроль, привилегированный контейнер);

– недостатки криптографической защиты — передача или хранение без шифрования либо с устаревшими алгоритмами;

– недостатки наблюдаемости — регистрация событий не ведётся, ведётся неполно или журналы не защищены;

– недостатки доверия к источникам — устанавливаемое ПО не проверяется на подлинность или берётся из недоверенных источников.

Классификация обладает свойством полноты относительно базы: каждая запись относится ровно к одному классу по второму основанию и одной группе по первому, поэтому классификацию можно рассматривать как разбиение множества недостатков и использовать при агрегировании оценок риска.

Системообразующая угроза для рассматриваемого объекта — эксплуатация ошибок конфигурирования сервисов серверной инфраструктуры Linux. Её источники: внешний нарушитель без полномочий, внешний нарушитель с действительными учётными данными, внутренний нарушитель из числа пользователей или администраторов, а также нарушитель через цепочку поставки ПО и конфигураций. Категории нарушителей и их возможности определяются по методике оценки угроз [46].

Риски, индуцированные этой угрозой, делятся на четыре группы — технические, информационные, экономические и правовые. Верхний уровень дерева угроз показан на рисунке 2.

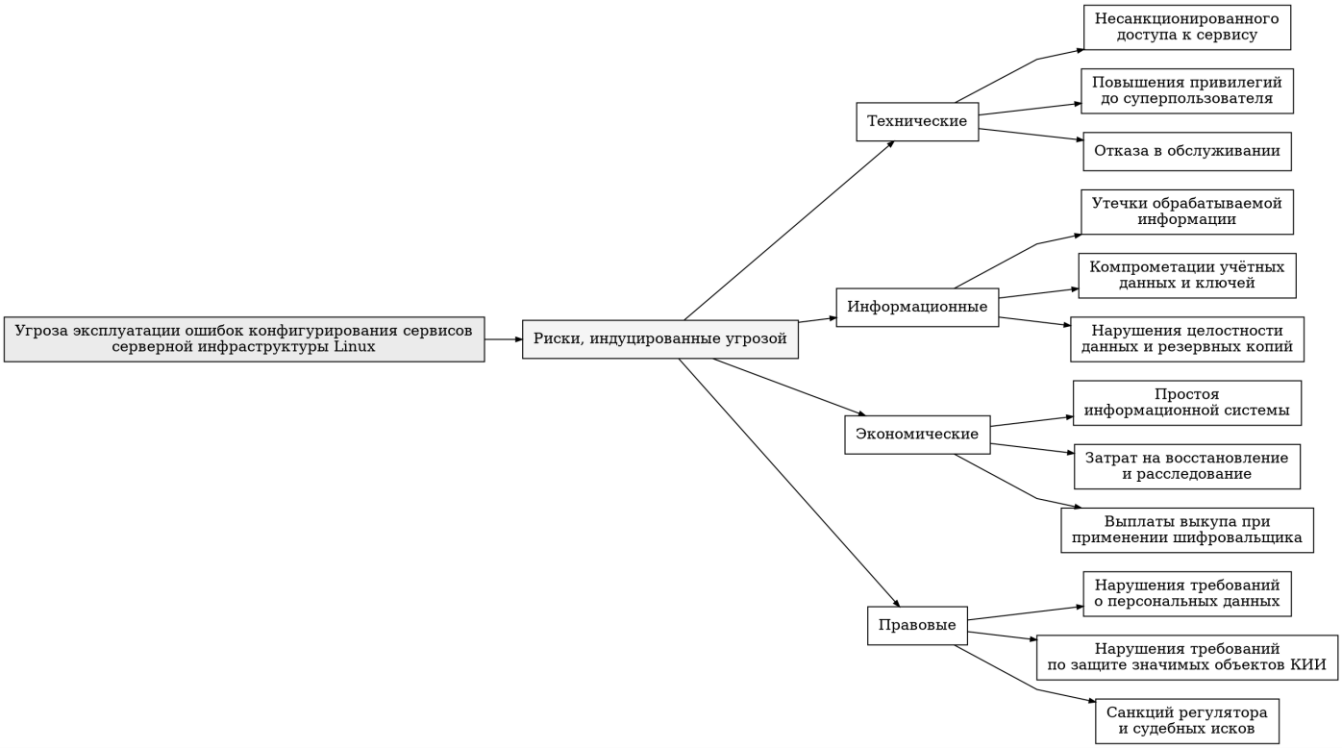


Рисунок 2 – Дерево угроз и индуцированных ими рисков серверной инфраструктуры Linux

Технические риски отражают последствия для самой инфраструктуры: несанкционированный доступ к сервису, повышение полномочий до суперпользователя, закрепление, перемещение внутри периметра, нарушение работоспособности. Информационные — последствия для данных: утечка информации ограниченного доступа, компрометация учётных данных и ключей, нарушение целостности данных и резервных копий; масштаб таких утечек в стране подтверждается статистикой InfoWatch [6]. Экономические — простой системы, затраты на восстановление и расследование, выплата выкупа при шифровальщике. Правовые — нарушение требований законодательства о персональных данных [40] и о безопасности КИИ [41, 45], а также санкции по итогам проверок регулятора.

Дальше дерево детализируется по группам сервисов. Фрагменты для первых четырёх и последующих четырёх групп приведены на рисунках 3 и 4.

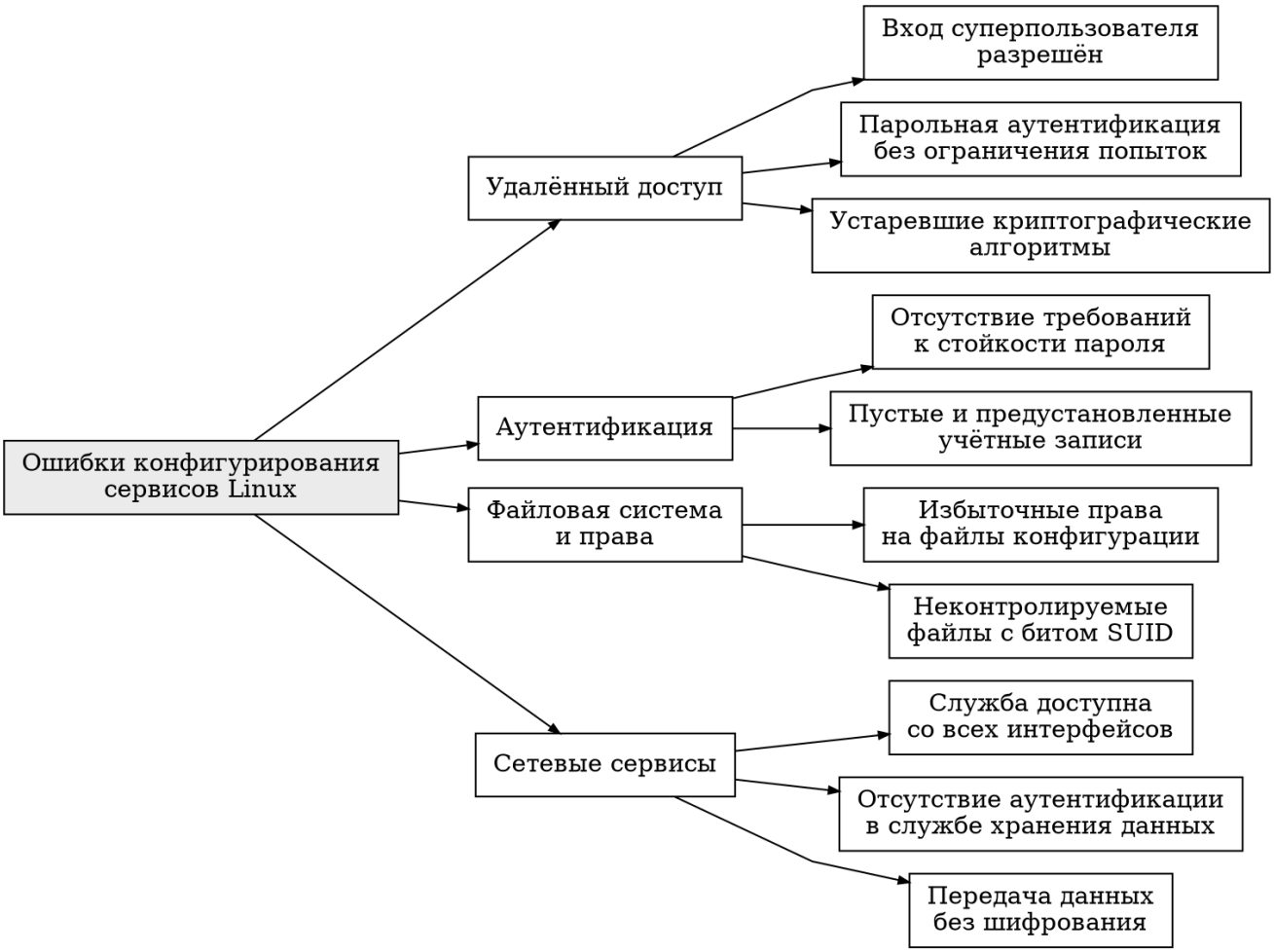


Рисунок 3 – Фрагмент дерева угроз: удалённый доступ, аутентификация, файловая система, сетевые сервисы

Особенность построенного дерева в том, что его листья соответствуют записям базы соответствий, а связь листа с техникой задаётся отношением из подраздела 1.5. Благодаря этому дерево — не иллюстрация, а структура данных: каждому листу во второй главе сопоставляется мера риска отдельного недостатка, а узлам верхних уровней — агрегированная мера риска группы.



Рисунок 4 – Фрагмент дерева угроз: изоляция, планировщики, журналирование, управление пакетами

Отдельно стоит вопрос связности. Дерево показывает принадлежность недостатка к группе, но не отражает того, что эксплуатация одного недостатка открывает путь к следующему. Например, доступная со всех интерфейсов служба хранения данных даёт нарушителю точку входа, отсутствие в ней аутентификации — содержимое, найденные в нём учётные данные — вход через сервер защищённой оболочки, а правило безусловного повышения полномочий — права суперпользователя. Четыре недостатка, каждый из которых по отдельности можно счесть некритичным, вместе образуют полную цепочку захвата узла — что и подтверждают практические разборы атак [3]. Формализация таких цепочек и расчёт риска их успешности вынесены в третью главу и опираются на аппарат графов атак [59, 61].

1.7 Выводы по первой главе

В первой главе серверная инфраструктура Linux исследована как объект защиты и решена первая задача работы — построена модель угроз на основе базы конфигурационных недостатков.

Построена модель объекта защиты: выделены восемь групп сервисов и механизмов, определяющих защищённость, введены обозначения для формализации снимка конфигурации и достижимости активов, определены наблюдаемые в самой системе свойства, образующие признаковое пространство для оценки критичности.

Обосновано выделение ошибок конфигурирования в самостоятельный класс источников риска. Показано, что такой недостаток не является дефектом кода, не привязан к версии, не получает идентификатора в справочниках, имеет иной жизненный цикл и возвращается из-за конфигурационного дрейфа, а потому не принимается на вход существующими средствами количественной оценки.

Разобрана нормативная база: требования формулируются в терминах наличия меры, результат проверки двоичный, а средств количественного сравнения недостатков по риску нормативные документы не дают.

Сформирована база соответствий «недостаток — техника ATT&CK — ущерб», охватывающая все восемь групп сервисов, и определена структура её записи, задающая единое признаковое пространство. Показано, что полученное отношение образует двудольный граф, используемый далее для сценариев эксплуатации.

Выполнена классификация недостатков по двум основаниям и построено дерево угроз и индуцированных рисков, листья которого соответствуют записям базы. Тем самым получен результат первой задачи — база соответствий и дерево угроз, — на котором строится вся дальнейшая работа: количественная оценка критичности во второй главе, сценарии эксплуатации в третьей, система оценки в четвёртой и меры риск-регулирования в пятой.

СПИСОК ЛИТЕРАТУРЫ

1 Usage statistics and market share of Linux for websites : статистика использования операционных систем на веб-серверах / W3Techs, Q-Success. – URL: https://w3techs.com/technologies/details/os-linux (дата обращения: 13.09.2026). – Текст : электронный.

2 О мерах по обеспечению технологической независимости и безопасности критической информационной инфраструктуры Российской Федерации : Указ Президента Российской Федерации от 30.03.2022 № 166. – Доступ из справ.-правовой системы «КонсультантПлюс». – Текст : электронный.

3 Степанова Е. А. Эксплуатация уязвимости операционной системы Astra Linux / Е. А. Степанова, Д. А. Елизаров, Е. Е. Мурзалева // Прикаспийский журнал: управление и высокие технологии. – 2025. – № 1 (69). – С. 86–90. – Текст : непосредственный.

4 Актуальные киберугрозы: IV квартал 2024 года – I квартал 2025 года : аналитический отчёт / Positive Technologies // CISOCLUB. – 2025. – URL: https://cisoclub.ru/aktualnye-kiberugrozy-iv-kvartal-2024-goda-i-kvartal-2025-goda/ (дата обращения: 12.09.2026). – Текст : электронный.

5 Positive Technologies назвала тренды кибератак уходящего года // CNews. – 2024. – URL: https://safe.cnews.ru/news/line/2024-12-26_positive_technologies_nazvala_trendy (дата обращения: 12.09.2026). – Текст : электронный.

6 За три года в России утекло 4,5 млрд записей персональных данных : по данным Экспертно-аналитического центра InfoWatch // CISOCLUB. – 2026. – URL: https://cisoclub.ru/model-ugroz-bezopasnosti-informacii/ (дата обращения: 12.09.2026). – Текст : электронный.

7 Русин М. Как обеспечить безопасность ОС Linux по рекомендациям ФСТЭК России / М. Русин ; BI.ZONE // Хабр. – 2025. – URL: https://habr.com/ru/companies/bizone/articles/950982/ (дата обращения: 12.09.2026). – Текст : электронный.

8 CVE Program : common vulnerabilities and exposures / The MITRE Corporation. – URL: https://www.cve.org (дата обращения: 12.09.2026). – Текст : электронный.

9 National Vulnerability Database / National Institute of Standards and Technology. – URL: https://nvd.nist.gov (дата обращения: 12.09.2026). – Текст : электронный.

10 Банк данных угроз безопасности информации / ФСТЭК России, ГНИИИ ПТЗИ ФСТЭК России. – URL: https://bdu.fstec.ru (дата обращения: 12.09.2026). – Текст : электронный.

11 Common Vulnerability Scoring System v3.1 : Specification Document / Forum of Incident Response and Security Teams. – FIRST.Org, 2019. – URL: https://www.first.org/cvss/v3-1/specification-document (дата обращения: 12.09.2026). – Текст : электронный.

12 Common Vulnerability Scoring System version 4.0 : Specification Document / Forum of Incident Response and Security Teams. – FIRST.Org, 2023. – URL: https://www.first.org/cvss/v4-0/specification-document (дата обращения: 12.09.2026). – Текст : электронный.

13 Exploit Prediction Scoring System (EPSS) : model documentation / Forum of Incident Response and Security Teams. – URL: https://www.first.org/epss (дата обращения: 12.09.2026). – Текст : электронный.

14 OpenSCAP : open source security compliance solution. – URL: https://www.open-scap.org (дата обращения: 12.09.2026). – Текст : электронный.

15 Lynis : security auditing tool for Linux, macOS and UNIX-based systems / CISOfy. – URL: https://cisofy.com/lynis/ (дата обращения: 12.09.2026). – Текст : электронный.

16 CIS-CAT Pro Assessor : configuration assessment tool / Center for Internet Security. – URL: https://www.cisecurity.org/cybersecurity-tools/cis-cat-pro/ (дата обращения: 12.09.2026). – Текст : электронный.

17 ScanOVAL для Astra Linux : средство анализа защищённости от известных уязвимостей / ФСТЭК России. – URL: https://bdu.fstec.ru/site/scanoval (дата обращения: 12.09.2026). – Текст : электронный.

18 Wazuh : the open source security platform. Documentation. – URL: https://documentation.wazuh.com (дата обращения: 12.09.2026). – Текст : электронный.

19 CIS Benchmarks : secure configuration guidelines / Center for Internet Security. – URL: https://www.cisecurity.org/cis-benchmarks (дата обращения: 12.09.2026). – Текст : электронный.

20 Эпидемии в телекоммуникационных сетях / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2017. – 284 с. – (Теория сетевых войн ; вып. 1). – Текст : непосредственный.

21 Атакуемые взвешенные сети / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2017. – 284 с. – (Теория сетевых войн ; вып. 2). – Текст : непосредственный.

22 Социальные сети и деструктивный контент / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2017. – 284 с. – (Теория сетевых войн ; вып. 3). – Текст : непосредственный.

23 Социальные сети и риск-мониторинг / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2019. – 284 с. – (Теория сетевых войн ; вып. 4). – Текст : непосредственный.

24 Социальные сети и психологическая безопасность / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2020. – 284 с. – (Теория сетевых войн ; вып. 5). – Текст : непосредственный.

25 Сетео-информационная эпидемиология / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2021. – 284 с. – (Теория сетевых войн ; вып. 6). – Текст : непосредственный.

26 Картография защищаемого киберпространства / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2022. – 372 с. – (Теория сетевых войн ; вып. 7). – Текст : непосредственный.

27 Организационно-правовая защита сетей / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2023. – 228 с. – (Теория сетевых войн ; вып. 8). – Текст : непосредственный.

28 SELinux User's and Administrator's Guide / Red Hat, Inc. – URL: https://access.redhat.com/documentation/ (дата обращения: 12.09.2026). – Текст : электронный.

29 Лиманова Н. И. Основные механизмы безопасности в Linux / Н. И. Лиманова, А. С. Анашкин // Бюллетень науки и практики. – 2024. – Т. 10, № 2. – С. 404–406. – DOI 10.33619/2414-2948/99/39. – Текст : непосредственный.

30 Двенадцать советов по повышению безопасности Linux : пер. с англ. / RUVDS // Хабр. – 2017. – URL: https://habr.com/ru/companies/ruvds/articles/343892/ (дата обращения: 12.09.2026). – Текст : электронный.

31 OpenSSH : sshd_config manual page / OpenBSD Project. – URL: https://man.openbsd.org/sshd_config (дата обращения: 12.09.2026). – Текст : электронный.

32 Linux-PAM : System Administrators' Guide. – URL: https://man7.org/linux/man-pages/man8/pam.8.html (дата обращения: 12.09.2026). – Текст : электронный.

33 sudoers(5) : Sudo manual / T. C. Miller. – URL: https://www.sudo.ws/docs/man/sudoers.man/ (дата обращения: 12.09.2026). – Текст : электронный.

34 Docker Engine security : documentation / Docker, Inc. – URL: https://docs.docker.com/engine/security/ (дата обращения: 12.09.2026). – Текст : электронный.

35 ГОСТ Р 56546–2015. Защита информации. Уязвимости информационных систем. Классификация уязвимостей информационных систем. – Москва : Стандартинформ, 2015. – 12 с. – Текст : непосредственный.

36 Common Weakness Enumeration : перечень типов слабостей программного и аппаратного обеспечения / The MITRE Corporation. – URL: https://cwe.mitre.org (дата обращения: 12.09.2026). – Текст : электронный.

37 Yin Z. An empirical study on configuration errors in commercial and open source systems / Z. Yin, X. Ma, J. Zheng [et al.] // Proceedings of the 23rd ACM Sympo-

sium on Operating Systems Principles. – Cascais : ACM, 2011. – P. 159–172. – Текст : непосредственный.

38 Xu T. Systems approaches to tackling configuration errors: a survey / T. Xu, Y. Zhou // ACM Computing Surveys. – 2015. – Vol. 47, No. 4. – Art. 70. – 41 p. – Текст : непосредственный.

39 Об информации, информационных технологиях и о защите информации : Федеральный закон от 27.07.2006 № 149-ФЗ. – Доступ из справ.-правовой системы «КонсультантПлюс». – Текст : электронный.

40 О персональных данных : Федеральный закон от 27.07.2006 № 152-ФЗ. – Доступ из справ.-правовой системы «КонсультантПлюс». – Текст : электронный.

41 О безопасности критической информационной инфраструктуры Российской Федерации : Федеральный закон от 26.07.2017 № 187-ФЗ. – Доступ из справ.-правовой системы «КонсультантПлюс». – Текст : электронный.

42 ГОСТ Р 50922–2006. Защита информации. Основные термины и определения. – Москва : Стандартинформ, 2008. – 12 с. – Текст : непосредственный.

43 Об утверждении Требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах : приказ ФСТЭК России от 11.02.2013 № 17. – Доступ из справ.-правовой системы «КонсультантПлюс». – Текст : электронный.

44 Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных : приказ ФСТЭК России от 18.02.2013 № 21. – Доступ из справ.-правовой системы «КонсультантПлюс». – Текст : электронный.

45 Об утверждении Требований по обеспечению безопасности значимых объектов критической информационной инфраструктуры Российской Федерации : приказ ФСТЭК России от 25.12.2017 № 239. – Доступ из справ.-правовой системы «КонсультантПлюс». – Текст : электронный.

46 Методика оценки угроз безопасности информации : методический документ : утверждён ФСТЭК России 05.02.2021. – Москва : ФСТЭК России, 2021. – 83 с. – Текст : непосредственный.

47 Рекомендации по безопасной настройке операционных систем Linux : методический документ : утверждён ФСТЭК России 25.12.2022. – Москва : ФСТЭК России, 2022. – Текст : непосредственный.

48 ГОСТ Р ИСО 31000–2019. Менеджмент риска. Принципы и руководство. – Москва : Стандартинформ, 2020. – 20 с. – Текст : непосредственный.

49 ГОСТ Р ИСО/МЭК 27005–2010. Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности. – Москва : Стандартинформ, 2011. – 51 с. – Текст : непосредственный.

50 Scarfone K. Guide to General Server Security : NIST Special Publication 800-123 / K. Scarfone, W. Jansen, M. Tracy. – Gaithersburg : NIST, 2008. – 53 p. – Текст : непосредственный.

51 Guide for Conducting Risk Assessments : NIST Special Publication 800-30 Rev. 1 / Joint Task Force Transformation Initiative. – Gaithersburg : NIST, 2012. – 95 p. – Текст : непосредственный.

52 Security Technical Implementation Guides / Defense Information Systems Agency. – URL: https://public.cyber.mil/stigs (дата обращения: 12.09.2026). – Текст : электронный.

53 Common Attack Pattern Enumeration and Classification / The MITRE Corporation. – URL: https://capec.mitre.org (дата обращения: 12.09.2026). – Текст : электронный.

54 MITRE ATT&CK : база знаний тактик и техник нарушителя / The MITRE Corporation. – URL: https://attack.mitre.org (дата обращения: 12.09.2026). – Текст : электронный.

55 CIS Ubuntu Linux 22.04 LTS Benchmark : v2.0.0 / Center for Internet Security. – East Greenbush, 2024. – URL: https://www.cisecurity.org/benchmark/ubuntu_linux (дата обращения: 12.09.2026). – Текст : электронный.

56 Waltermire D. The Technical Specification for the Security Content Automation Protocol (SCAP) : NIST Special Publication 800-126 Rev. 3 / D. Waltermire, S. Quinn, H. Booth [et al.]. – Gaithersburg : NIST, 2018. – 62 p. – Текст : непосредственный.

57 Nessus : vulnerability assessment solution / Tenable, Inc. – URL: https://www.tenable.com/products/nessus (дата обращения: 12.09.2026). – Текст : электронный.

58 MaxPatrol VM : система управления уязвимостями / Positive Technologies. – URL: https://www.ptsecurity.com/ru-ru/products/mpvm/ (дата обращения: 12.09.2026). – Текст : электронный.

59 Ou X. MulVAL: a logic-based network security analyzer / X. Ou, S. Govindavajhala, A. W. Appel // Proceedings of the 14th USENIX Security Symposium. – Baltimore, 2005. – P. 113–128. – Текст : непосредственный.

60 Краткие научно-методические рекомендации по формированию и выполнению технических заданий в области обеспечения информационной безопасности / А. Г. Остапенко, М. Е. Волкова, Д. А. Нархов [и др.] // Информация и безопасность. – 2020. – Т. 23, вып. 4. – С. 551–560. – Текст : непосредственный.

61 Wang L. Network Security Metrics / L. Wang, S. Jajodia, A. Singhal. – Cham : Springer, 2017. – 207 p. – Текст : непосредственный.